

UNIT-2 CRYPTOGRAPHY MECHANISMS

Structure

- 2.0 Introduction
- 2.1 Objectives
- 2.2 Introduction to Cryptography
 - 2.2.1 Functions of Cryptography
- 2.3 Steganography
- 2.4 Encryption and Decryption
- 2.5 Encryption Scheme: Public Key and Private Key Distribution
- 2.6 Commonly used Crypto Algorithms
 - 2.6.1 DES
 - 2.6.2 RSA
- 2.7 Electronic Signature
- 2.8 Authentication and Authorisation
 - 2.8.1 Hash Functions
 - 2.8.2 Access Control Derivatives/Mechanisms
 - 2.8.3 Key establishment, management and certification
 - 2.8.4 Trusted third parties and public key certificates
 - 2.8.5 Pseudorandom numbers and sequences
- 2.9 Public Key Infrastructure/ Data Encryption Standard
- 2.10 Summary
- 2.11 Terminal Questions
- 2.12 Solutions/Answers
- 2.13 References/Further Readings

2.0 INTRODUCTION

One of the most powerful and important methods for security in computer systems is to encrypt sensitive records and messages in transit and in storage. Cryptography has a long and colorful history. Historically, four groups of people have used and contributed to the art of Cryptography, the military, the diplomatic corps, diarists, and lovers. The military has had the most sensitive role and has shaped the field.

At present, information and data security plays a vital role in the security of the country, the security of the corporate sector and also of every individual, working for personal benefit.

2.1 OBJECTIVES

At the end of this unit, you will be able to:

- discuss what is conventional cryptography and types of ciphers;
- explain the meaning of encryptions ;

- describe Algorithms used in Cryptology;
- discuss encryption schemes, their merits and demerits;
- explain the meaning and use of Electronic Signature;
- discuss cryptographic hash functions and cryptographic protocols and mechanism;
- describe methodology for ensuring the secure distribution of keys for cryptographic purposes; and
- explain the concept of trusted third parties and public key certificates.

2.2 INTRODUCTION to CRYPTOGRAPHY

The message or data to be encrypted, also known as the plaintext, is transformed by a function that is parameterized by a KEY. The output of the encryption process, known as the cipher text, is then transmitted through the insecure communication channel. The art of breaking ciphers is called cryptanalysis. The art of devising ciphers (cryptography) and breaking them (cryptanalysis) is collectively known as cryptology.

Mathematically, $C = E_k(P)$ meaning that the encryption of the plaintext P using key K gives the cipher text C . Similarly, $P = D_k(C)$ implies the decryption of C to get the plaintext again. It then follows that $D_k(E_k(P)) = P$.

Types of Ciphers

Conventionally, there are two types of ciphers. They are the following:

Substitution Ciphers: Another letter or group of letters to disguise it replaces each letter or group of letters. One of the oldest known ciphers is the Caesar Cipher, attributed to Julius Caesar. For example, using this cipher, attack becomes DWWDFFN. Here plaintext is in lowercase and cipher text in uppercase letters. A slight generalisation of the Caesar cipher allows the cipher text alphabet to be shifted by k letters, instead of always 3. In this case k becomes a key to the general method of circularly shifted alphabets. Example in Fig. 1 shows:

JULIUSCAESAR Plaintext

EFGEFGEFGEFG Key EFG repeated

10 21 12 09 21 19 03 01 05 19 01 18 Plaintext, numeric

05 06 07 05 06 07 05 06 07 05 06 07 Key EFG, numeric

15 19 11 12 19 20 06 07 02 22 07 21 Cipher text (Plain XOR key)

Figure 1

A FUNCTION BASED SUBSTITUTION CIPHER

A substitution cipher can be made unbreakable by using a long no repeating key. Such a key is called one-time pad. A one-time pad may be formed by using words from a book starting from specific place known to both the sender and receiver. For example, starting with this sentence and using XOR on ASCII encoding of the letters of the plaintext and of the key. The encryption would proceed as given in Fig. 2. The textual equivalent of the cipher text is not given because it contains nonprintable ASCII characters. The message can be deciphered by reversing the process. XOR each letter of the cipher text with the ASCII representation of the key produces the ASCII encoding of a letter of the plaintext.

JULIUSCAESAR Plaintext

FOREXAMPLEST key-starting sentence (one-time pad)

74 85 76 73 85 83 67 65 69 83 65 82 Plaintext, ASCII

70 79 82 69 88 65 77 80 76 69 83 84 Key ASCII

12 26 30 12 13 18 14 17 09 22 18 06 Cipher text = Plain XOR key

Figure 2

A ONE-TIME PAD

One-time pad ciphers are unbreakable because they give no information to the cryptanalyst. The primary difficulty with one-time pad is that the key must be as long as the message itself, so key distribution becomes a problem, since a different pad must be used for each communication.

Transposition Ciphers: It operates by reordering the plaintext symbols, whereas substitution ciphers preserve the order of the plaintext symbols but try to disguise them. An example of it Columnar transposition is described below:

C O N S U L T Keyword

1 4 3 5 7 2 6 Column numbers

E N C R Y P T Plaintext:

I O N I S P E E N C R Y P T I O N S P E R F O R M E D B Y W R I T I N G T H E P L A I N T E X T R E F O R M E D B Y W R I T I

N G T H E P L cipher text:

A I N T E X T E I R B N A P P E T P X C N O W T N N O F Y G I R I R R H T T E D I L T Y S M I E E FIGURE for Transposition Cipher.

The other types of ciphers which are present are as follows: (The Economic Times, 2021, p.1)

1. **Polyalphabetic substitution cipher:** In this cipher, a blended alphabet is utilized to encrypt the plaintext, but at random points it would convert to a special uncommon mixed alphabet which denotes the alteration with an uppercase letter in the Ciphertext.
2. **Transposition Cipher:** This cipher is also known as Rail Fence Cipher and is a permutation of the plaintext.

3. **Permutation Cipher:** The locations assumed by plaintext are moved to a uniform system in this cipher so that the ciphertext amounts to a permutation of the plaintext.
4. **Private-key Cryptography:** In this cipher, even the attacker is mindful of the plaintext and corresponding ciphertext. The sender and receiver must have a pre-shared key. The shared key is kept undisclosed from all other parties and is used for encryption as well as decryption. DES and AES algorithms are examples of this type of cipher. This cryptography is also known as "symmetric key algorithm".
5. **Public-key Cryptography:** In this cipher, two different keys - public key and private key - are used for encryption and decryption. The sender uses the public key to carry out encryption, whereas the receiver is kept in the dark about the private key. This is also known as asymmetric key algorithm.

2.2.1 Functions of Cryptography

Base cryptographic functions provide the most flexible means of developing cryptography applications. All communication with a cryptographic service provider (CSP) occurs through these functions. A CSP is an independent module that performs all cryptographic operations. At least, one CSP is needed with each application that uses cryptographic functions. A single application can occasionally use more than one CSP. Base cryptographic functions are in the following broad group

Service provider function
Key generation and exchange function
Object encoding and decoding functions
Data Encryption and decryption functions
Hash and Digital functions

The five key functions of cryptography are: (Gary C. Kessler, 2021, p.1)

1. **Privacy/Confidentiality:** Making sure that no one can persue the message except the intended receiver.
2. **Authentication:** The process of showing and establishing one's identity.
3. **Integrity:** Assuring the receiver that the received message has not been distorted in any manner from the initial.
4. **Non-repudiation:** A process or a way to prove that the sender really sent this message.
5. **Key exchange:** The approach by which crypto keys are shared between sender and receiver.

Check your progress 1

Spend 3 Min.

Fill in the blanks:

- i) The output of the encryption process is known as _____.
- ii) Substitution and _____ are two types of Ciphers.

2.3 STEGANOGRAPHY

It is one of the techniques of hiding secret data within a non-secret, ordinary file or manages to avoid being deleted. It will be decoded at the station. In modern digital steganography, data is first encrypted or obfuscated in some other way and then inserted, using a special algorithm, into data that is part of a particular file format such as JPEG image, audio or video file. The secret message can be embedded into ordinary data files in many different ways. One technique is to hide data in bits that represent the same color pixels repeated in a row in an image file. By applying, the encrypted data to this redundant data in some inconspicuous way, the result will be an image file that appears identical to the original image but that has noise patterns of regular, unencrypted data.

It can be divided into following five types:

- Text Steganography
- Image Steganography
- Video Steganography
- Audio Steganography
- Network Steganography

The benefit of this method is that the data is extra and twice as safe i.e., that first that it is out of sight and the second is that it is encrypted. Because of this process, it becomes challenging for the person to first locate or trace the data and then encrypt it.

Some of the well known uses of stego around the world include:

Head of the messenger was shaved and a tattoo was done on the head and after the hair grew back, the messenger was sent and the recipient again shaved the hair to read the tattooed message, U.S. Marine Corps Navaho code talkers of WWII, Disappearing ink and microdots, Osama bin Laden's pre-recorded videos that are re-played on TV stations around the world contain hidden messages, September 11 attacks in New York City, Washington, D.C. (Gary C. Kessler, 2001, p.1)

2.4 ENCRYPTION AND DECRYPTION

Encryption is one common method of protecting information transmitted over unreliable links. In practice, the following is the mechanism of encryption:

- A) The information (text) is encrypted (encoded) from its initial readable form (called clear text), to an internal form (called cipher text). This internal text form, although readable, does not make any sense.
- B) The cipher text can be stored in a readable file, or transmitted over unprotected channels.

- C) The receiver must decrypt (decode) it back into clear text to understand the meaning of the cipher text.

Since it is likely that people may become involved with negative aspects of computing, care has to be taken to see that encryption algorithms are free from statistical and mathematical weakness and that they are not feasible to break computationally so that cracking becomes prohibitively time-consuming. At the other end, the computational complexity of encryption and decryption should be reasonable because they represent processing overhead that increases communication delays.

2.5 ENCRYPTION SCHEME: PUBLIC KEY AND PRIVATE KEY DISTRIBUTION

Symmetric-key and public-key encryption schemes have various advantages and disadvantages, some of which are common to both. This section highlights a number of these and summarizes features pointed out in previous sections.

Advantages of symmetric-key cryptography

- 1) Symmetric-key ciphers can be designed to have high rates of data throughput. Some hardware implementations achieve of hundreds of megabytes per second, while software implementations may attain throughput rates in the megabytes per second range. Keys for symmetric-key ciphers are relatively short.
- 2) Symmetric-key ciphers can be employed as primitives to construct various cryptographic mechanisms including pseudorandom number generators, hash functions and computationally efficient digital signature schemes, to name just a few.
- 3) Symmetric-key ciphers can be composed to produce stronger ciphers. Simple transformations which are easy to analyse, but are weak on their own weak, can be used to construct strong product ciphers.
- 4) Symmetric-key encryption is perceived to have an extensive history, although it must be acknowledged that, notwithstanding the invention of rotor machines earlier, much of the knowledge in this area has been acquired subsequent to the invention of the digital computer, and in particular, the design of the Data Encryption Standard in the early 1970s.

ii) Disadvantages of symmetric-key cryptography

- 1) In a two-party communication, the key must remain secret at both ends.
- 2) In a large network, there are many key pairs to be managed. Consequently, effective key management requires the use of an unconditionally trusted TTP.
- 3) In a two-party communication between entities μ and η , sound cryptographic practice dictates that the key be changed frequently and perhaps for each communication session.
- 4) Digital signature mechanisms arising from symmetric-key encryption typically require either large keys for the public verification function or the use of a TTP.

iii) Advantages of public-key cryptography

- 1) Only the private key must be kept secret (authenticity of public keys must, however, be guaranteed).
- 2) The administration of keys on a network requires the presence of only a functionally trusted TTP as opposed to an unconditionally trusted TTP. Depending on the mode of usage, the TTP might only be required in an “off-line” manner, as opposed to in real time.
- 3) Depending on the mode of usage, a private key/public key pair may remain unchanged for considerable periods of time, e.g., many sessions (even several years).
- 4) Many public-key schemes yield relatively efficient digital signature mechanisms. The key used to describe the public verification function is typically much smaller than for the symmetric-key counterpart.
- 5) In a large network, the number of keys necessary may be considerably smaller than in the symmetric-key scenario.

iv) Disadvantages of public-key encryption

- 1) Throughput rates for the most popular public-key encryption methods are several orders of magnitude slower than the best-known symmetric-key schemes.
- 2) Key sizes are typically much larger than those required for symmetric-key encryption and the size of public-key signatures is larger than that of tags providing data origin authentication from symmetric-key techniques.
- 3) No public-key scheme has been proven to be secure (the same can be said for block ciphers). The most effective public-key encryption schemes found to date have their security based on the presumed difficulty of a small set of number-theoretic problems.
- 4) Public-key cryptography does not have as extensive a history as symmetric-key encryption, being discovered only in the mid 1970s.

Summary of comparison

Symmetric-key and public-key encryptions have a number of complementary advantages.

Current cryptographic systems exploit the strengths of each. Public-key encryption techniques may be used to establish a key for a symmetric-key system being used by communicating entities and in this scenario, we can take advantage of the long-term nature of the public/private keys of the public-key scheme and the performance efficiencies of the symmetric-key scheme. Since data encryption is frequently the most time-consuming part of the encryption process, the public-key scheme for key establishment is a small fraction of the total encryption process.

To date, the computational performance of public-key encryption is inferior to that of symmetric-key encryption. There is, however, no proof that this must be the case. The important points in practice are:

1. Public-key cryptography facilitates efficient signatures (particularly non-repudiation) and key management; and
2. Symmetric-key cryptography is efficient for encryption and some data integrity applications.

Please answer the following Self Assessment Question.

Check your progress 2**Spend 3 Min.**

What are the basic advantages of Asymmetric Key?

2.6 COMMONLY USED CRYPTO ALGORITHMS

The Secret-Key Algorithm: A system where one secret key shared is called Symmetric or secret key cryptography. This approach is known as Caesar's Cipher and usually functions in the alphabet substitution technique. This is a very simple technique and in today's world encryption systems aren't as straightforward as one thinks.

2.6.1 Data Encryption Standard (DES):

It was originally developed by IBM and was adopted as an NBS Standard in 1977 to shield susceptible data, unarranged government data. It is no longer secure in its original form (Wayner, 1995), but in modified form it is still useful. DES is a symmetric cryptosystem, so the cipher text is decrypted using the same key. It operates on 64-bit (8 byte) blocks of input at a time. The algorithm, which is parameterized by a 56-bit key, has 19 distinct stages. The first stage is a key independent transposition on the 64-bit plaintext. The last stage is the exact inverse of this transposition. The stage prior to the last one exchanges the leftmost 32 bits with the rightmost 32 bits. The remaining 16 stages are functionally identical but are parameterized by different functions of the key.

The steps of the DES encryption algorithm operating on 64-bit block are:

$$L_0R_0 = t(\text{input})$$

Repeat for $n = 1$ to 16

$$L_n = R_{n-1}$$

$$R_n = L_{n-1} \oplus f(R_{n-1}, K_n)$$

$$\text{Output} = t^{-1}(L_{16}R_{16})$$

Obviously, DES is a complex algorithm. But critics say that its key is too short, which makes it susceptible to brute-force attack. In 1977, two Stanford Cryptography researchers, Diffie and Hellman designed a machine to break DES and estimated it could be built for 20 Million dollars. Given a small piece of plaintext and matched cipher text, this machine could find the key by exhaustive search of the entry key space in under 1 day. Nowadays such a machine would cost perhaps 1 million dollars. A detailed design for a machine that can break DES by exhaustive search in about four hours is presented in (Wiener, 1994).

Another calculation says that software encryption is 1000 times slower than hardware encryption and that, a high-end home computer can still do about 3, 50, 000 encryption/sec in software and is probably idle 2 million second/month. This idle time could be put to use breaking DES. Probably the most innovative idea for breaking DES is the CHINESE LOTTERY (Quisquater and Girault, 1990). With this, every radio and television has to be equipped with a cheap DES chip capable of performing 1 million encryption /sec in hardware.

As DES was deciphered by the researchers as mentioned above, it was replaced by AES encryption algorithm. The greatest drawback is low encryption length and now TLS 1.2 is used. **(Jay Thakkar, 2020, p.1)**

Public Key Algorithms: A cryptosystem where two different keys are used for encryption and decryption is called Asymmetric or Public key System. The key distribution is the most important thing whatever may be the cryptosystem. If somehow the key is stolen, the total system would be worthless. The primary advantage of public key cryptography is increased security. The secret keys don't have to be transmitted or revealed to anyone. Another advantage of this system is that public key and the secret key can both be used for encoding as well as decoding. Their functions are interchangeable.

2.6.2 RSA Algorithm:

These are the initials of three discoverers (Rivest, Shamir, and Adleman) at M.I.T. They all produced this algorithm, which is totally based on modular mathematics of Number theory. It is an asymmetric cryptography algorithm because it uses two different keys for encoding and decoding.

One of the properties of modular arithmetic is the possibility of computing multiplicative inverses. That is, given an integer e in the range of $[0, n-1]$, it is sometimes possible to find a unique integer d in the range $[0, n-1]$ such that

$$ed \bmod n = 1$$

For example, 3 and 7 are multiplicative inverses modulo 20, because $21 \bmod 20 = 1$

1. It can be shown that integer $e \in [0, n-1]$ has a unique multiplicative inverse mod n when e and n are relatively prime, that is when $\gcd(e, n) = 1$. ($\gcd$ denotes the greatest common divisor). The no. of positive integers that are relatively prime to n is a function denoted as $\phi(n)$. For $n = pq$ and p and q are prime, it can be shown that

$$\phi(n) = (p-1)(q-1)$$

For number P set of $[0, n-1]$ it can be shown that the equation

$$C = P^e \bmod n \quad (\text{First}) \text{ is an inverse of}$$

$$P = C^d \bmod n \quad (\text{Second})$$

If $ed \bmod \phi(n) = 1$ where $\phi(n) = (p-1)(q-1)$

First equation is used for encryption by several public keys algorithms with e and n as the key. Decryption is performed using second equation with d and n as keys.

Since the key (e, n) is public, only the number d in the decryption pair (d, n) is private.

This above idea is used in case of RSA also. The determination of n , d and e is prescribed in the following way:

Choose two large primes, p and q , each greater than 10^{100} Calculate $n = pq$ and $\phi(n) = (p-1)(q-1)$

Assume a number d to be a large, random integer that is relatively prime to $\phi(n)$ that is such that $ed \bmod \phi(n) = 1$

Calculate e such that $ed \bmod \phi(n) = 1$

These parameters may be used to encipher plaintext P where $0 \leq P < n$. If the plaintext is longer, it must be broken into strings smaller than n . Cipher text is obtained as $C = P^e \bmod n$

n. C may be then decrypted as $P = c^d \text{ mod } n$. Steps of algorithm ensures that encryption and decryption are inverses of each other.

Yet breaking of RSA is not reported yet wide use of it has been tremendous increased. A cryptanalyst would presumably use factoring to derive d from n and e, which are publicly known.

Hybrid Encryption is the best of both symmetric and asymmetric encryption and the same is creating tough encryption techniques. But, both of them come with both pros and cons, symmetric encryption method is fast for large data encryption but falls short of identity verification. The asymmetric encryption method is quite opposite, it is slow but have public and private key pair which is a must when it comes to cyber safety.

Now, in the present times, both identity verification and speed is a must and that is how the process of hybrid encryption came into existence. (Jay Thakkar, 2020, p.1)

Check your progress 3

Spend 3 Min.

Why is RSA algorithm more widely used than DES?

.....

.....

.....

2.7 ELECTRONIC SIGNATURE

People authenticate other people by recognising their faces, voices and handwriting. Signatures on letterhead paper handle proof of signing raised seals and so on. Handwriting, paper, and ink experts can usually detect tampering. But none of these options are available electronically. That's why the concept of Digital signature came into existence to authenticate electronic documents.

A Digital Signature is a technique by which it is possible to secure electronic information in such a way that the originator of the information, as well as the integrity of the information, can be verified. This procedure of guaranteeing the origin and the integrity of the information is also called Authentication.

The authenticity of many legal, financial, and other documents is determined by the presence or absence of an authorized handwritten signature. For a computerised message system to replace the physical transport of paper and ink documents handwritten signatures have to be replaced by Digital Signatures. Basically what is needed, is a system by which one party can send a "signed" message to another party in such a way that

- A) The receiver can verify the claimed identity of the sender.
- B) The sender cannot repudiate the contents of the message.
- C) The receiver cannot possibly have concocted the message himself/ herself.

A digital signature is only a technique that can be used for different authentication purposes. For an E-record, it comes functionally very close to the traditional hand-written signatures. The user himself/ herself can generate key pair by using specific crypto software. Now Microsoft IE and Netscape, allow the user to create his/ her own key pair.

Here, the most important thing is how can the user be sure that public keys belong to his/ her partner only? In this case, a third party (TTP) will guarantee the relationship between the identity and the public keys. The TTP are popularly called Certified Authorities (CAs).

Digital Certificate: These certificates are provided by CAs to authenticate that a particular site is globally secured. There are so many reputed CAs all over the world. Some of them are VeriSign from USA and Thawte Consulting from South Africa. Popular India CAs are SafeScript Ltd, TCS, IDRB, MTNL Ltd and NIC.

Digital certificates contain the following:

Issuer, Issued to, organization name, organization unit, validity, Version, Public Keys, Thumbprint, algorithms etc.

Secure Socket Layer (SSL) is the widely used protocol for digital certificates. The Uniform Resource Locator (URL) starts with “https” instead of “http” and are secured by SSL. At the bottom of the window, a lock symbol appears for SSL. Generally, 128 bits SSL are used. 40 bits SSL are also available.

Comparison between Electronic Signature and Digital Signature: (Aparajita Balaji, 2019, p.1)

Section 2 (ta) of Information Technology Act, 2000 had defined electronic signatures as:

“Authentication of any electronic record by a subscriber by means of the electronic technique specified in the second schedule and includes digital signature.”

This definition has made the Act technologically neutral as it recognizes both digital and electronic signatures.

It is important to note that electronic signatures are not safe as they are not encrypted and are likely to be tampered unlike that of digital signatures which includes private key and public key for encryption and decryption.

Some of the commonly used electronic signatures are email signatures, web based signatures, digitized image of a signature. Therefore, it is advised that digital signatures should be used as they are more secure and have more legal weightage.

Electronic Signatures have no expiry or validity period unlike a digital signature which is valid up to a maximum of three years.

Electronic Signatures are used for verifying a document unlike digital signatures which are used for securing a document.

Section 2(1) (p) of Information Technology Act, 2000 had defined digital signatures as:

“Authentication of any electronic record by a subscriber by means of the electronic technique specified in the second schedule and includes digital signature.”

Digital signatures are widely used for personal use, signing tenders, bidding, e-filing for ROC or income tax or for GST.

It follows an approach of using hash function i.e., usage of private key and a public key which is a two way protection system.

The process involves obtaining a digital signature certificate from a certifying authority which are set up and controlled by the mechanisms and law of the country. In order to transmit the message, public key and private key is used to encrypt and decrypt the message.

Check your progress 4 Spend 3 Min.

Is digital signature equivalent to handwritten signature legally?

2.8 AUTHENTICATION AND AUTHORISATION

Authentication is a term which is used (and often abused) in a very broad sense. By itself, it has little meaning other than to convey the idea that some means has been provided to guarantee that entities are who they claim to be, or that information has not been manipulated by unauthorized parties. Authentication is specific to the security objective which one is trying to achieve. Examples of specific objectives include access control. The host countries might not permit secrecy on the channel; one or both countries might want the ability to monitor all communications. Jack and Bond, however, would like to be assured of the identity of each other, and of the integrity and origin of the information they send and receive.

Authentication is one of the most important of all information security objectives. Until the mid 1970s it was generally believed that secrecy and authentication were intrinsically connected. With the discovery of hash functions and digital signatures, it was realized that secrecy and authentication were truly separate and independent information security objectives. It may at first not seem important to separate the two but there are situations where it is not only useful but essential. For example, if a two-party communication between Jack and Bond is to take place where Jack is in one country and Bond in another, the host countries might not permit secrecy on the channel; one or both countries might want the ability to monitor all communications. Jack and Bond, however, would like to be assured of the identity of each other, and of the integrity and origin of the information they send and receive.

The preceding scenario illustrates several independent aspects of authentication. If Jack and Bond desire assurance of each other's identity, there are two possibilities to consider.

- 1) Jack and Bond could be communicating with no appreciable time delay. That is, they are both active in the communication in "real time".
- 2) Jack or Bond could be exchanging messages with some delay. That is, messages might be routed through various networks, stored, and forwarded at some later time. In the first instance Jack and Bond would want to verify identities in real time. This might be accomplished by Jack sending Bond some challenge, to which Bond is the only entity which can respond correctly. Bond could perform a similar action to identify Jack. This type of authentication is commonly referred to as *entity authentication* or more simply phrase challenge for *identification*.

For the second possibility, it is not convenient to challenge and await response, and moreover the communication path may be only in one direction. Different techniques are now required to authenticate the originator of the message. This form of authentication is called *data origin authentication*.

Thus, *Data origin authentication* or *message authentication* techniques provide to one for originality.

In the authentication process, verification of users is done and determines whether the person is a user or not while in the authorization process validation of users is done wherein determination is done as to whether the user has requisite permission to access the data or the information. Authentication is done prior to authorization process. The process of authentication requires user's login details while authorization only requires user's privilege or security levels. **(Geeks for Geeks, 2020,p.1)**

2.8.1 HASH FUNCTIONS

One of the fundamental primitives in modern cryptography is the cryptographic hash function, often informally called a one-way hash function simplified definition of hash function is given below.

Definition A *hash function* is a computationally efficient function mapping binary strings of arbitrary length to binary strings of some fixed length, called *hash-values*.

The most common cryptographic uses of hash functions are with digital signatures and for data integrity. With digital signatures, a long message is usually hashed (using a publicly available hash function) and only the hash-value is signed. The party receiving the message then hashes the received message and verifies that the received signature is correct for this hash-value. This saves both time and space compared to signing the message directly, which would typically involve splitting the message into appropriate-sized blocks and signing each block individually. Note here that the inability to find two messages with the same hash-value is a security requirement, since otherwise, the signature on one message hash-value would be the same as that on another, allowing a signer to sign one message and at a later point in time claim to have signed another.

Hash functions may be used for data integrity as follows. The hash-value corresponding to a particular input is computed at some point in time. The integrity of this hash-value is protected in some manner. At a subsequent point in time, to verify that the input data has not been altered, the hash-value is recomputed using the input at hand, and compared for equality with the original hash-value. Specific applications include virus protection and software distribution.

A third application of hash functions is their use in protocols involving prior commitments, including some digital signature schemes and identification protocols.

Hash functions as discussed above are typically publicly known and involve no secret keys. When used to detect whether the message input has been altered, they are called *modification detection codes* (MDCs). Related to these are hash functions which involve a secret key, and provide data origin authentication as well as data integrity; these are called *message authentication codes* (MACs).

Some of the popular hash functions include: **(Tutorials Point, p.1)**

- 1) Message Digest is a 128-bit hash function which gives confidence about veracity of transmitted file. But it is no longer in practice as there were successful collisions i.e., analytical attack in 2004.
- 2) Secure Hash Functions family consists of four SHA algorithms; SHA-0, SHA-1, SHA-2, and SHA-3. The latest is Keccak algorithm which was chosen by NIST in October 2012 as the new SHA-3 standard which offers many benefits, such as efficient performance and good resistance for attacks.
- 3) The RIPEMD is an acronym for RACE Integrity Primitives Evaluation Message Digest. This set of hash functions was devised by open research community and generally known as a family of European hash functions.
- 4) Whirlpool is a 512-bit hash function which has stemmed from the revised edition of Advanced Encryption Standard (AES). One of the designer was Vincent Rijmen, a co-creator of the AES.

2.8.2 Access control derivatives/ mechanisms

Definition A *cryptographic protocol (protocol)* is a distributed algorithm defined by a sequence of steps precisely specifying the actions required of two or more entities to achieve a specific security objective.

Remark (*protocol vs mechanism*) As opposed to a protocol, a *mechanism* is a more general term encompassing protocols, algorithms (specifying the steps followed by a single entity), and non-cryptographic techniques (e.g., hardware protection and procedural controls) to achieve specific security objectives.

Protocols play a major role in cryptography and are essential in meeting cryptographic goals. Encryption schemes, digital signatures, hash functions, and random number generation are among the primitives which may be utilized to build a protocol.

Protocol and mechanism failure

Definition A *protocol failure* or *mechanism failure* occurs when a mechanism fails to meet the goals for which it was intended, in a manner whereby an adversary gains advantage not by breaking an underlying primitive such as an encryption algorithm directly, but by manipulating the protocol or mechanism itself.

Example (*mechanism failure*) Jack and Bond are communicating using a stream cipher.

Messages which they encrypt are known to have a special form: the first twenty bits carry information which represents a monetary amount. Active adversaries can simply XOR an appropriate bit string into the first twenty bits of cipher text and change the amount. While the adversary has not been able to read the underlying message, she has been able to alter the transmission. The encryption has not been compromised but the protocol has failed to perform adequately; the inherent assumption that encryption provides data integrity is incorrect.

Example (*forward search attack*) Suppose that in an electronic bank transaction the bit field which records the value of the transaction is to be encrypted using a public-key scheme. This simple protocol is intended to provide privacy of the value field – but does it? An adversary could easily take all possible entries that could be plaintext in this field and encrypt them using the public encryption function. (Remember that by the very nature of public-key encryption this function must be available to the adversary.) Each of the cipher texts with the one which is actually encrypted in the transaction, the adversary can determine the plaintext. Here the public-key encryption function is not compromised, but rather the way it is used.

2.8.3 KEY ESTABLISHMENT, MANAGEMENT AND CERTIFICATION

This section gives a brief introduction to methodology for ensuring the secure distribution of keys for cryptographic purposes.

Definition *Key establishment* is any process whereby a shared secret key becomes available to two or more parties, for subsequent cryptographic use.

Definition *Key management* is the set of processes and mechanisms which support key establishment and the maintenance of ongoing keying relationships between authorized parties, including replacing older keys with new keys as and when necessary.

Key establishment can be broadly subdivided into *key agreement* and *key transport*.

Many and protocols have been proposed to provide key establishment.

Key management encompasses techniques and procedures supporting:

1. initialisation of system users within a domain;
2. generation, distribution, and installation of keying material;
3. controlling the use of keying material;
4. update, revocation, and destruction of keying material; and
5. Storage, backup/recovery, and archival of keying material.

Key management through symmetric-key techniques

One solution which employs symmetric-key techniques involves an entity in the network which is trusted by all other entities. This entity is referred to as a *trusted third party* (TTP). Each entity shares a distinct symmetric key with the TTP. These keys are assumed to have been distributed over a secured channel. If two entities subsequently wish to communicate, the TTP generates a key (sometimes called a *session key*) and sends it encrypted under each of the fixed keys. This approach has certain advantages and disadvantages.

A symmetric cryptographic system is a system involving two transformations – one for the originator and one for the recipient – both of which make use of either the same secret key (symmetric key) or two keys easily computed from each other. An asymmetric cryptographic system is a system involving two related transformations– one defined by a public key (the public transformation), and another defined by a private key (the private transformation) – with the property that it is computationally infeasible to determine the private transformation from the public transformation.

Advantages

1. It is easy to add and remove entities from the network.
 2. Each entity needs to store only one long-term secret key. Disadvantages
1. All communications require initial interaction with the TTP.
 2. The TTP must store long-term secret keys.
 3. The TTP has the ability to read all messages.
 4. If the TTP is compromised, all communications are insecure.

Key management through public-key techniques

There are a number of ways to address the key management problem through public-key techniques. Each entity in the network has a public/private encryption key pair. The public key along with the identity of the entity is stored in a central repository called a *public file*.

Advantages of this approach include:

1. No trusted third party is required.
2. The public file could reside with each entity.
3. Only public keys need to be stored to allow secure communications between any pair of entities, assuming the only attack is that by a passive adversary.

The key management problem becomes more difficult when one must take into account an adversary who is *active* (i.e. an adversary who can alter the public file containing public keys). Please answer the following Self Assessment Question.

Check your progress 5

Spend 1 Min.

Key establishment can be divided into _____ and key transport.

2.8.4 TRUSTED THIRD PARTIES AND PUBLIC KEY CERTIFICATES

Definition A TTP is said to be *unconditionally trusted* if it is trusted on all matters. For example, it may have access to the secret and private keys of users, as well as be charged with the association of public keys to identifiers.

Various third party services require different types of trust and competency in the third party. For example, a third party possessing secret decryption keys (or entity authentication keys) must be trusted not to disclose encrypted information (or impersonate users). A third party required (only) to bind an encryption public key to an identity must still be trusted not to create false associations and thereafter impersonate an entity. In general, three levels of trust in a third party T responsible for certifying credentials for users may be distinguished. Level 1: T knows each user's secret key. Level 2: T does not know users' secret keys, but can create false credentials without detection. Level 3: T does not know users' secret keys, and generation of false credentials is detectable

Definition A TTP is said to be *functionally trusted* if the entity is assumed to be honest and fair but it does not have access to the secret or private keys of users.

Public-key certificates

The distribution of public keys is generally easier than that of symmetric keys, since secrecy is not required. However, the integrity (authenticity) of public keys is critical.

Primary advantages offered by public-key (vs symmetric-key) techniques for applications related to key management include:

- 1) *Simplified key management.* To encrypt data for another party, only the encryption public key of that party need be obtained. This simplifies key management as only authenticity of public keys is required, not their secrecy. . The situation is analogous for other types of public-key pairs, e.g., signature key pairs.
- 2) *On-line trusted server not required.* Public-key techniques allow a trusted on-line server to be replaced by a trusted off-line server plus any means for delivering authentic public keys (e.g., public-key certificates and a public database provided by an un-trusted on-line server). For applications where an on-line trusted server is not mandatory, this may make the system more amenable to scaling, to support very large numbers of users.

- 3) *Enhanced functionality*. Public-key cryptography offers functionality which typically cannot be provided cost-effectively by symmetric techniques (without additional online trusted third parties or customized secure hardware). The most notable such features are non-repudiation of digital signatures, and true (single-source) data origin authentication.

A *public-key certificate* consists of a *data part* and a *signature part*. The data part consists of the name of an entity, the public key corresponding to that entity, possibly additional relevant information (e.g., the entity's street or network address, a validity period for the public key, and various other attributes). The signature part consists of the signature of a TTP over the data part.

2.8.5 PSEUDORANDOM NUMBERS AND SEQUENCES

Random number generation is an important primitive in many cryptographic mechanisms.

For example, keys for encryption transformations need to be generated in a manner which is unpredictable to an adversary. Generating a random key typically involves the selection of random numbers or bit sequences. Random number generation presents challenging issues.

Often in cryptographic applications, one of the following steps must be performed:

- i) From a finite set of elements, select an element at random.
- ii) From the set of all sequences (strings) of length over some finite alphabet of symbols, select a sequence at random.
- iii) Generate a random sequence (string) of symbols of length over a set of symbols.

It is not clear what exactly it means to select at random or generate at random. Calling a number random without a context makes little sense. Is the number a random number?

A Pseudo Random Number Generator (Geeks for Geeks, 2019, p.1)

It refers to an algorithm that utilizes mathematical formulation to create series of random numbers. They produce a series of numbers assessing the properties of random numbers.

With the arrival of technology, computer programmers acknowledged the requirement for a way of announcing unpredictability into a computer program. In spite of this, unexpected as it may seem, it is tough to get a computer to do something by chance as computer trails the specified instructions unseeingly and is therefore totally foreseeable. It is not possible to create truly random numbers from deterministic thing like computers so this is a method expounded to generate random numbers using a computer.

Some of the advantages are that this system is efficient as it can create number in a short span of time, easy to determine if replaying the same sequence of numbers again at a later stage and lastly are periodic i.e., that the sequence will eventually repeat itself.

2.9 PUBLIC KEY INFRASTRUCTURE/ DATA ENCRYPTION STANDARD

A PKI stands for Public key Infrastructure in cryptography. Development in PKI occurred in the early 1970s at the British intelligence agency GCHQ where James Ellis and Clifford Cocks made popular

development for PKI. The sole purpose of PKI is to facilitate the best secure electronic transfer of information for digital activities. It is an arrangement that binds public keys with respective identities of entities. The binding is established through a process of registration and issuance of certificates at and by a Certificate authority (CA).

The deployment of PKI may be delegated by a CA to assure valid and correct registration, which is called registration Authority (RA). The Internet Engineering Task Force's RFC 3647 defines an RA. So, the RA is responsible for accepting request for digital certificates and authenticating the entity requested by the user. The most unique feature of PKI is that it uses a pair of keys to achieve the secured digital communication by comprising both private and public keys.

Therefore, an anatomy of PKI comprises of the following components:

- Public key certificate commonly referred as digital certificate (X 509 standard defines it)
- Private key tokens
- Certificate authority
- Registration Authority
- Certificate management System.

Data Encryption Standard:

DES (Data Encryption Standard) is a encryption algorithm which uses symmetric keys for cipher encryption. It uses 56 bits (+8 parity bits) in 16 rounds having a block size of 64 bits. It has been designed by IBM team and adopted by national Institute of standards of Technology (NIST). It was first published in 1975 (federal Register standardized in 1977. Its structure is Balanced Feistel Network and its successors are Triple DES, G-DES, DES-X, LOKO89 and ICE

TRIPLE DES is a symmetric key-block cipher which applies DES cipher in triplicate. It encrypts with first key (K1), decrypts with second key (K2) then decrypts with third key (K3). This is also a two-key variant where K1 and K3 are the same keys.

Though DES is no longer NIST's federal standard, it does not mean that it is no longer in use. Triple DES is still used today and it is considered a legacy encryption algorithm. But in practice, PKI has overcome the DES for ensuring digital communication system.

The main disadvantage of Public Key Infrastructure is that one of the keys i.e., public key is in a public domain and is therefore, likely to be misused. It is rarely seen that cryptographic schemes are compromised due to weakness in their design but very often it is compromised due to the poor key management. The same can be achieved by keeping private keys secret throughout. (**Tutorials Point, p.1**)

Let us now summarize the points covered in this unit.

2.10 SUMMARY

- Encryption is one common method of protecting information transmitted over unreliable lines where plain text is being converted to Cipher text and then again to plain text.
- Basically, there are two algorithms used for encryption. One is RSA and other one is DES.
- RSA is an asymmetric cryptography and DES is symmetric one.
- A system where one secret key shared is called Symmetric or Secret Key Cryptography.

- A cryptosystem where two different keys are used for encryption and decryption is called Asymmetric or Public Key System.
- Digital signature is a technique to secure electronic information in such a way that the originator of the information, as well as the integrity of information can be verified with proper authentication.
- Digital certificates are provided by Certified Authorities (CAs) to authenticate that a particular site is globally secured.
- There are five common CAs in India. They are Safescrypt Ltd, TCS, IDBFT, MTNL and NIC.
- A hash function is a computationally efficient function mapping binary strings of arbitrary length to binary strings of some fixed length called hash-values. The most common cryptographic uses of hash functions are with digital signatures and for data integrity.
- Key establishment is any process whereby a shared secret key becomes available to two or more parties, for subsequent cryptographic use.
- Key establishment can be subdivided into key agreement and key transport.
- Key management is the set of processes and mechanisms, which support key establishment and the maintenance of ongoing keying relationships between parties, including replacing older keys with new keys as and when necessary.

2.11 SOLUTIONS/ANSWERS

Check your progress

- 1) (i) Cipher text, (ii) Transposition
- 2) The advantages of Asymmetric keys are as follows:
 1. Only the private key must be kept secret
 2. The administration of keys on a network requires the presence of only a functionally trusted TTP as opposed to an unconditionally trusted TTP
 3. Depending on the mode of usage, a private key/public key pair may remain unchanged for considerable periods of time
- 3) RSA is asymmetric cryptographic algorithm and uses two different keys for encoding and decoding while DES is a symmetric cryptosystem and the cipher text is decrypted using the same key. It is a complex algorithm. So far no breaking of RSA has been reported though DES can be broken
- 4) According to Patrick W. Brown, Digital Signature technology may be employed to produce legally enforceable signatures in Electronic Data Interchange (EDI) among computer users within the same general guidelines and requirements as those developed for handwritten signatures on paper. Digital Signature technology may be employed to produce legally enforceable signatures in Electronic Data Interchange (EDI) among computer users within the same general guidelines and requirements as technology promises assurance at least equal to written signatures. From a legal

standpoint, this assurance remains to be tested in the evidentiary process. Business policies for organizational use of this technology are being created as the use of digital signature technology is adopted. Digital signatures may be used to provide assurances in distributed and networked computer environments where electronic transactions require a high degree of trust.

5) Key Agreement

2.12 REFERENCES/ FURTHER READINGS

- Aparajita Balaji (2019). Digital Signature and Electronic Signature as defined under the law. [https://blog.ipleaders.in/digital-electronicsignature/#:~:text=Sec%20%20\(ta\)%20of%20Information,schedule%20and%20includes%20digital%20signature.%E2%80%9D](https://blog.ipleaders.in/digital-electronicsignature/#:~:text=Sec%20%20(ta)%20of%20Information,schedule%20and%20includes%20digital%20signature.%E2%80%9D)
- Brown, P.W (1994). “Digital signatures: are they legal for electronic commerce”. *Communications Magazine*. IEEE. 32.9: 76 – 80.
- Gary C. Kessler (2001), Steganography: Hiding Data Within Data, p1; <https://www.garykessler.net/library/steganography.html>
- Gary C. Kessler (2021), An Overview of Cryptography, p1; <https://www.garykessler.net/library/crypto.html>
- Geeks for Geeks (2020), Difference between Authentication and Authorisation, p1; <https://www.geeksforgeeks.org/difference-between-authentication-and-authorization/>
- Geeks for Geeks (2020), Pseudo Random Number Generator, p1; <https://www.geeksforgeeks.org/pseudo-random-number-generator-prng/>
- J. Quisquater and M. Girault (1990). $2n$ -bit hash-functions using n -bit symmetric block cipher algorithms. *Advances in Cryptology, Proc. Eurocrypt'89, LNCS 434*, J.-J. Quisquater and J. Vandewalle, Eds., Springer-Verlag, 1990, pp. 102–109.
- J. Wiener (1994). Efficient DES Key Search. *TR-244. School of Computer Science*, Carleton University, Ottawa, Canada.
- Jay Thakkar (2020). Types of Encryption. p1. <https://www.thesslstore.com/blog/types-of-encryption-encryption-algorithms-how-to-choose-the-right-one/>
- Mlen Milenkovic (1992). *Operating System Concepts and design*. New York: McGraw-Hill, Inc.,
- Peter Wayner (1995). *Agents Unleashed: A Public Domain Look at Agent Technology*.
- Silberschatz. Galvin, Gagne (2006). *Operating System Concepts*. 7th ed. John Wiley & Sons.
- The Economic Times (2021). Definition of Ciphertext. p1; <https://economictimes.indiatimes.com/definition/ciphertext>
- Tutorials Point. Cryptography Hash Functions. p1; https://www.tutorialspoint.com/cryptography/cryptography_hash_functions.htm
- Tutorials Point. Public Key Infrastructure. p1; https://www.tutorialspoint.com/cryptography/public_key_infrastructure.htm